

# Agent Identity Control Plane

## Market & Competitive Analysis

Last updated: Dec 25, 2025

## Thesis

“Shadow AI” is not just a discovery/visibility problem. The unmet need is enforceable, explainable control at the moment an AI interaction crosses a trust boundary (data egress or tool execution), across both employees and production agents.

## The real problem to fix

- Employees paste sensitive code/data into consumer models because policies are slow and enforcement is weak.
- Agents can be manipulated (prompt injection) into using privileged connectors (SQL, tickets, cloud, email).
- Security teams cannot reliably answer: “who used what model with what data, and what actions did it trigger?”
- Existing controls are fragmented across IDE copilots, browser/SSE tools, LLM gateways, and agent runtimes.

## Who buys this

- **Primary buyer:** Security (AppSec / SecEng) + AI Platform / DevEx co-ownership.
- **Primary users:** platform engineers, security engineers, incident responders, developer enablement.
- **Economic buyer:** CISO / VP Eng (risk + productivity).

## Competitive landscape (how we differ)

- **SSE/CASB/DLP:** good at SaaS discovery and some policy enforcement, but weak at agent tool-call governance + receipts.
- **LLM gateways:** govern app→model traffic, but not the downstream tool actions, and usually not employee shadow AI.
- **Agent runtimes:** strong inside their own ecosystem; not cross-runtime and not a neutral control plane.
- **Observability/LLMOps:** traces and dashboards, but enforcement is limited or ad-hoc; receipts are not incident-grade.

## Why now

- Adoption is already broad; policy compliance lags and workarounds are common.
- Tool-enabled agents turn prompts into real side effects; the blast radius is growing.

- Regulated orgs increasingly demand auditability for AI-driven actions (not just model access).

# Go-to-market wedge for V0

Start narrow: pick a high-risk action surface and win by blocking/allowing with receipts.

## Recommended initial wedges

- Developer orgs: GitHub + Jira + Slack + internal DB access for coding agents and assistants.
- IT/Security: sanctioned routing + policy for a small number of AI endpoints + data redaction + audit receipts.
- Agent platform teams: tool/skill authorization + credential brokering for a small set of tools.

## Messaging that lands

- “Policy at the action boundary.”
- “Intent-bound capabilities + signed receipts.”
- “Works across employees and agents.”

## Risks & mitigations

- **Integration friction** → ship a thin PEP (proxy/wrapper) and support 1–2 killer connectors first.
- **Too compliance-y** → anchor on productivity + incident response, not “avoid fines”.
- **Crowded narratives** → differentiate with receipts + credential brokering + cross-runtime enforcement.